

Cyber Attribution

Yihao Lim

Why Attribute? The Importance of Who

- Cyber attribution is a necessary step to accountability.
- It serves as a basis for a response: for states in accordance with international law, and for the private sector (if it owns or manages attacked infrastructure) in accordance with national applicable laws.
- Cyber attribution is a **necessary precursor to retaliation – technical, legal or political**. And if a state has advanced attribution capabilities, it is in a better position to understand what has happened and appropriately react to a cyberattack.
- Attribution capabilities are therefore a crucial element in building a deterrence strategy against malicious behaviour.

☰ 🔍 Mon, Mar 16, 2026 | New Delhi 30 °C 🌤️ **Hindustan Times** 100

Home E-Paper India News World News Entertainment Dubai News LIVE Lifestyle Cities +

Smart Money Sports Delhi News Century of Leadership Bengaluru News Mumbai News Tech

Iran claims US built its Shahed drone's clone 'Lucas' to attack Arab nations: 'To damage our relations'

Iran's foreign minister Abbas Araghchi said that Tehran was ready to investigate the strikes on civilian areas in West Asian countries.

Updated on: Mar 15, 2026 6:21 PM IST

By [Arya Mishra](#) ✕



"We will welcome any regional initiative that leads to a just end to the war," Araghchi said. (AFP)

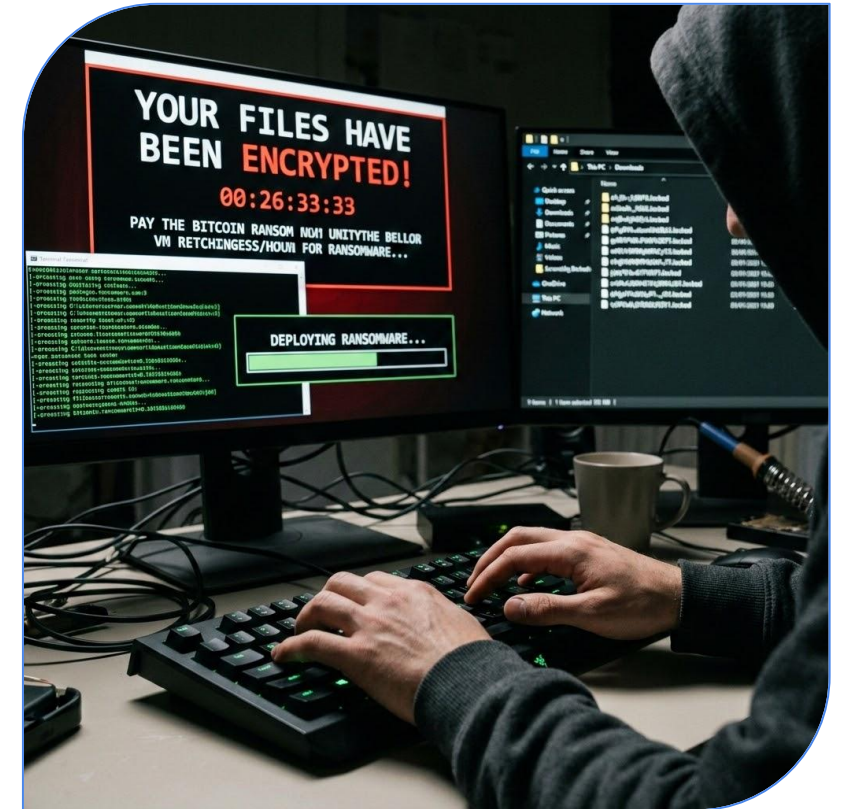
Iranian foreign minister Abbas Araghchi on Sunday said Tehran was ready to investigate the strikes on civilian areas in West Asian countries, while denying that they had struck any targets other than US bases and installations.

In an interview with Al-Araby Al-Jadeed website, Araghchi blamed the US and [Israel](#) for these attacks.

The Core Challenge

Attribution is inherently difficult because the internet offers adversaries significant advantages:

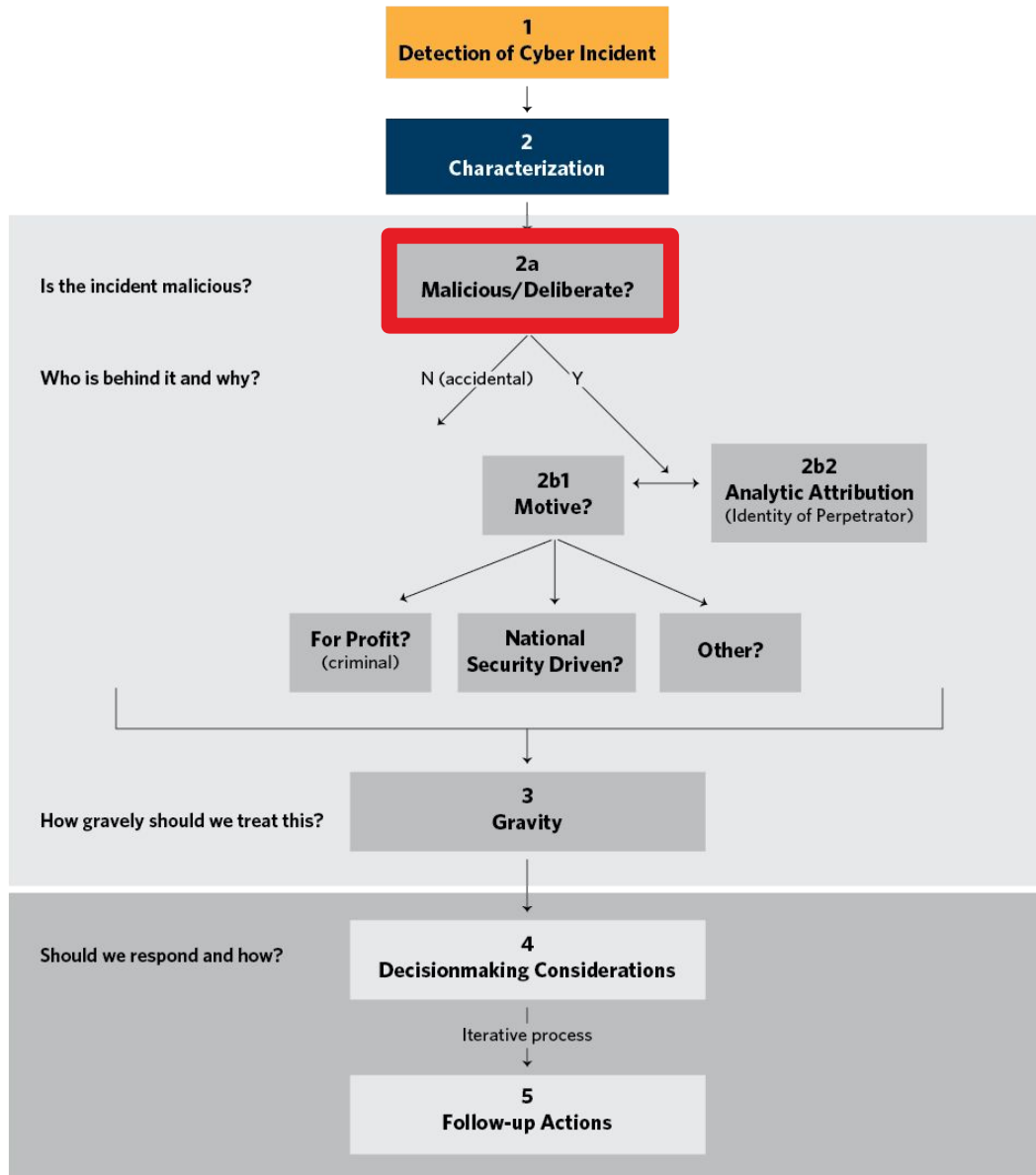
- Anonymity: Attackers can easily mask their location using proxy chains, Virtual Private Networks (VPNs), and The Onion Router (Tor).
- False Flags: Adversaries frequently use infrastructure, coding language, or malware artifacts associated with other groups or nations to deliberately mislead investigators.
- Shared Tools: Many sophisticated groups use commodity tools or stolen exploits, blurring the lines of origin.



The Core Challenge

Level	Focus (The "Who")	Evidence Used	Confidence Level
Level 1: Technical	The Malware/Tool (e.g., "This was a Lazarus Group attack.")	IOCs (IPs, domains, hashes), unique malware code, configuration files.	High (Easiest to achieve)
Level 2: Group/Cluster	The Cyber Threat Group (e.g., "The attack was carried out by APT41.")	Unique TTPs (how they move, escalate, and persist), shared infrastructure, specific time-of-day operations.	Medium
Level 3: Political/Nation-State	The Sponsoring Government (e.g., "APT41 is sponsored by the Chinese government.")	Non-technical evidence: geopolitical goals, victimology, statements by national security officials, operational overlap with state intelligence.	Low to Medium (Hardest to prove)

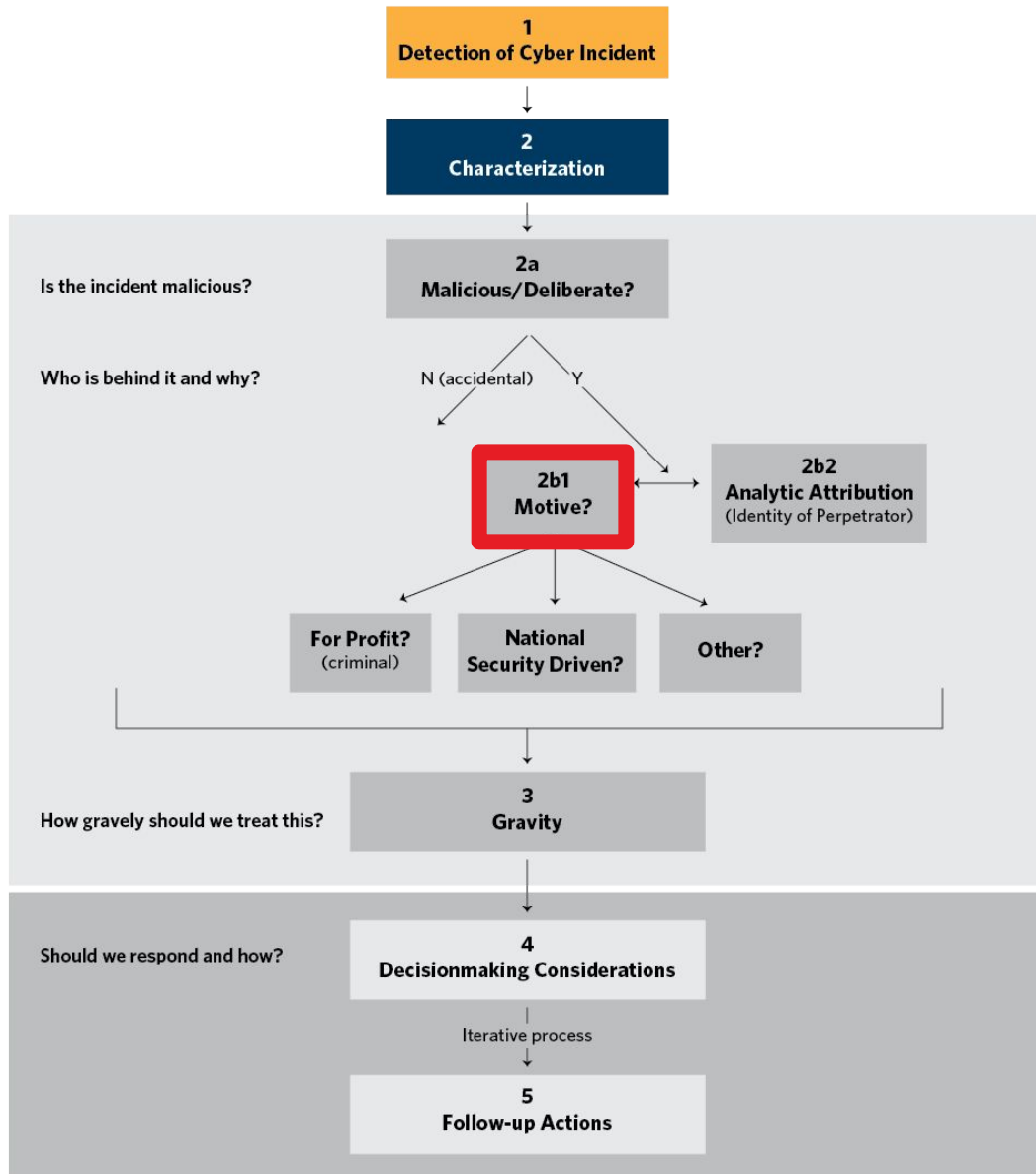
FIGURE 1
Characterization and Attribution Sequence



MALICIOUS OR DELIBERATE?

- Is the detected cyber anomaly the result of malicious action? Or has it been triggered by a technical failure, an innocent human error, or possibly a natural occurrence? On its face, this determination seems like a no-brainer.
- In practice, though, arriving at a definitive answer may not merely involve considerable time and effort, but also some anxiety until such an answer emerges—especially when the perpetrator of an anomaly tries to mask a malicious action as a technical or human error.

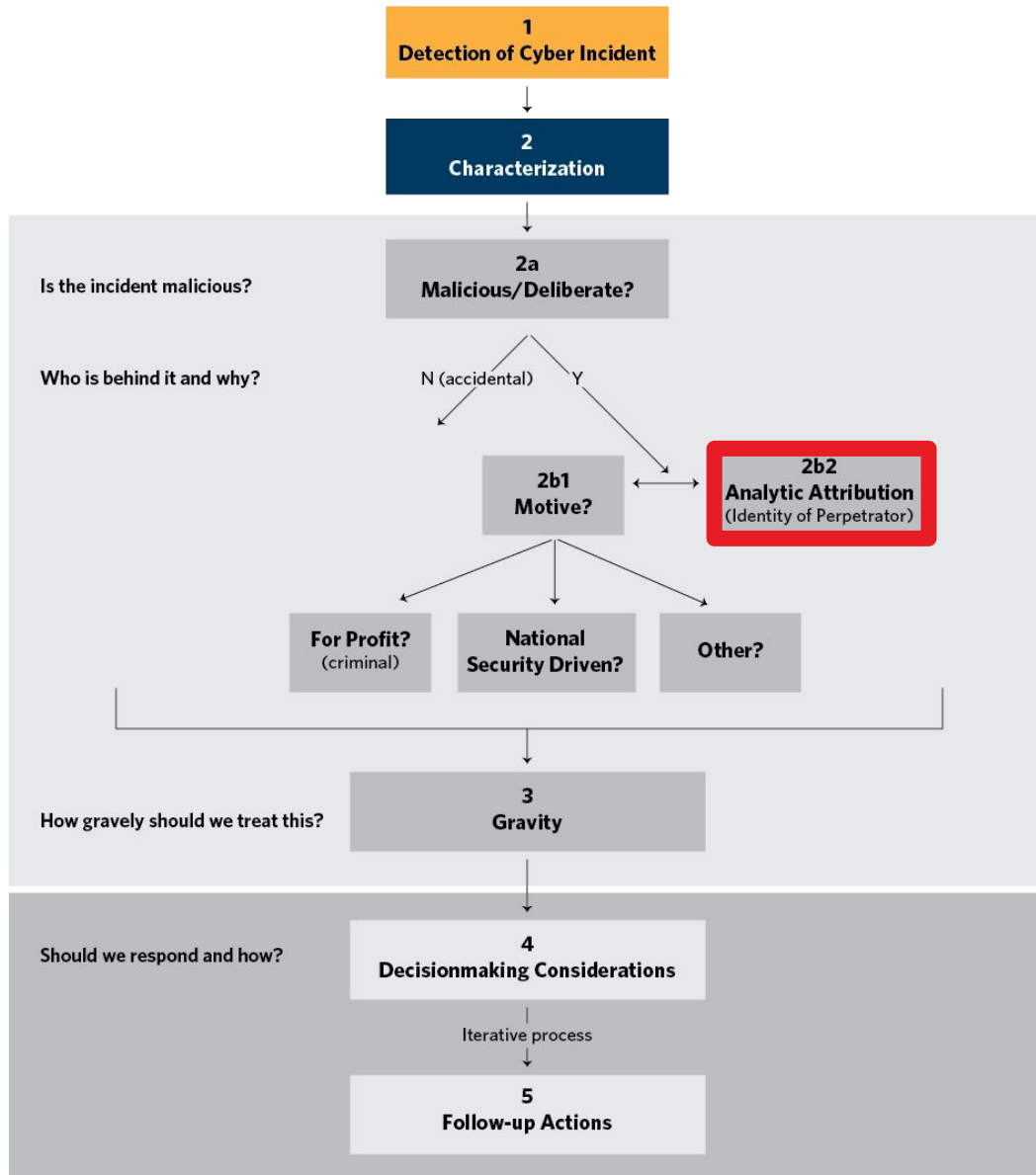
FIGURE 1
Characterization and Attribution Sequence



MOTIVE

- Assuming an investigation suggests a deliberate action with malicious intent, it is bound to take a while to assess its true consequences. While the effort to do so is ongoing, the natural next step is to ascertain the motive behind the adversarial action.
- Was it driven by criminal aims of one kind or another? Is it perhaps an action by a disgruntled employee? Is it a protest by anarchists or another ideological opponent?
- Or is it motivated by the national security of a foreign power or its proxy?
- If the latter, two other sets of questions quickly arise, each calling for an elaborate follow-up effort to figure out the precise motive.

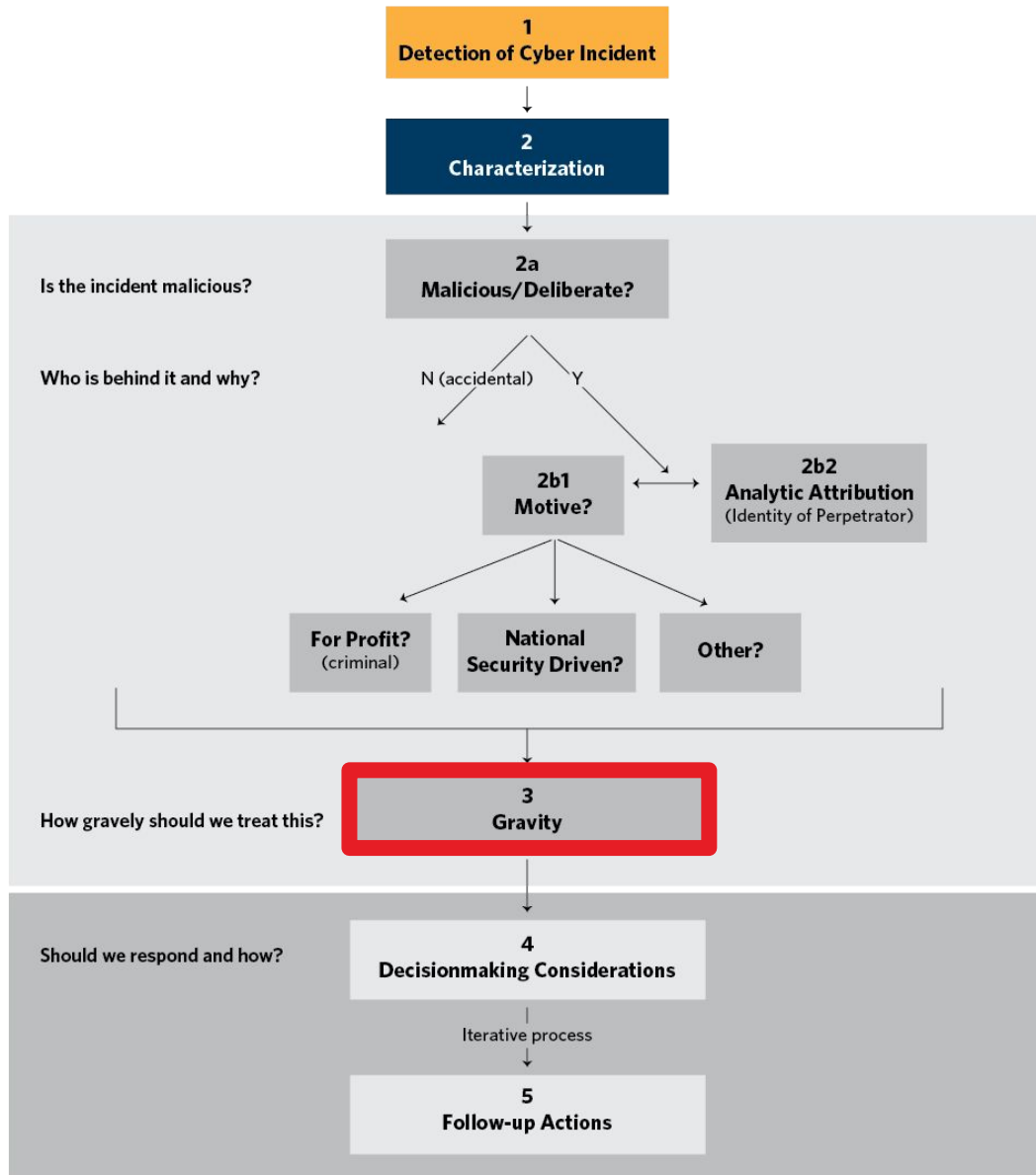
FIGURE 1
Characterization and Attribution Sequence



IDENTITY

- Another pressing matter is the identity of the perpetrator. And even more importantly, who stands behind them (who could be located far apart nationally, geographically, or institutionally)?
- And at what level of seniority was the operation approved or, at least, assisted/tolerated? Naturally, the first set of motivation-related questions already begins to touch on these questions, insofar as the effort to characterize an action must factor in the identity of the perpetrator.
- But often, just as in police investigations of criminal behavior, the process works in reverse order—namely, the likely motivation inferred from an action's parameters provides some clues as to the likely identity of its perpetrator.

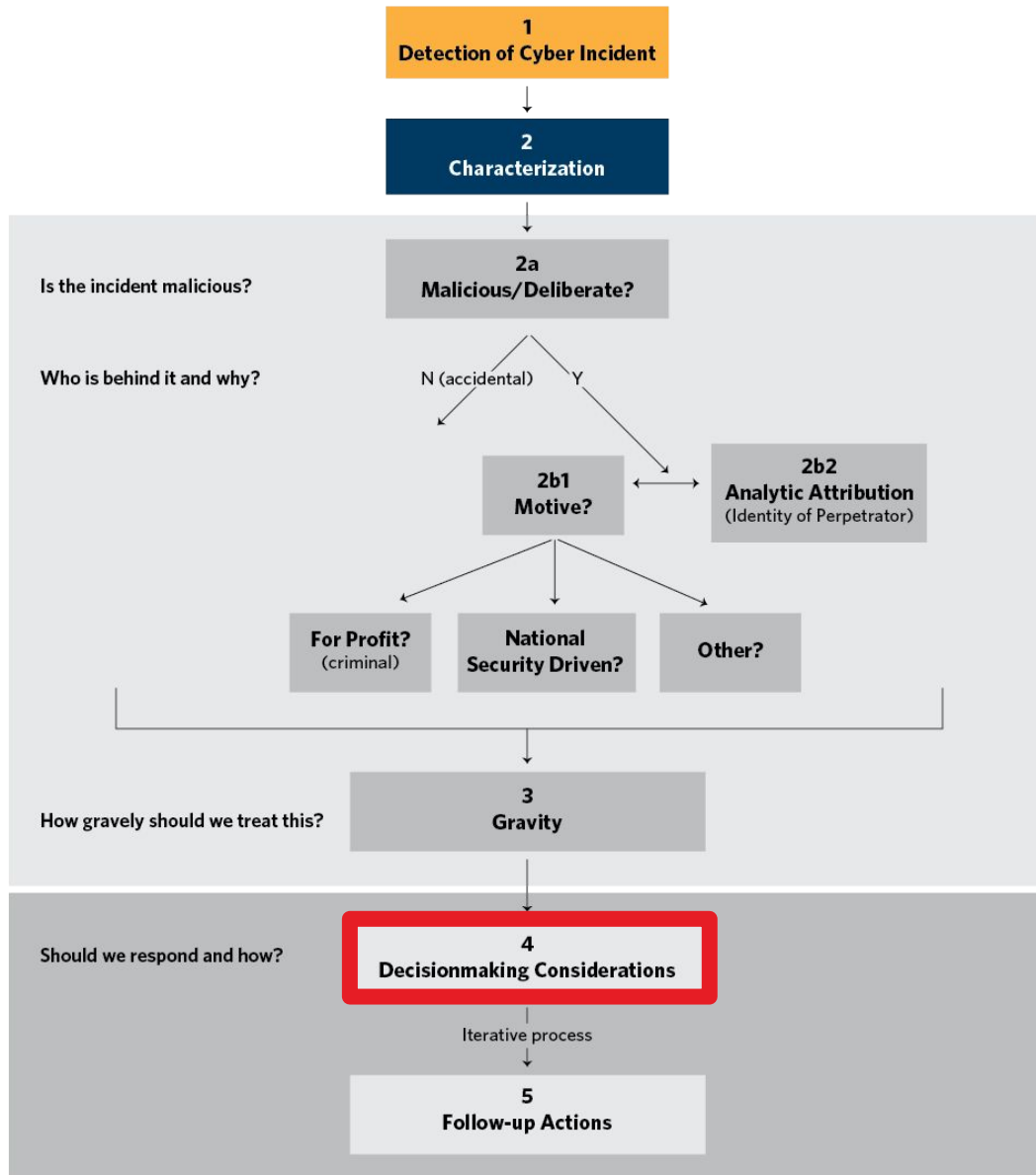
FIGURE 1
Characterization and Attribution Sequence



GRAVITY

- The next phase is determining the gravity of an action. This phase lends itself to a far more subjective determination than the preceding ones.
- Furthermore, it usually involves many other types of participants as well as considerations. In particular, six additional criteria come into play here to assess and characterize the gravity of an incident.
- These are:
 - The adversary's aim(s) and intended effect(s).
 - The actual effects of the action (which might be bigger, smaller, more localized, more widespread, more enduring, or more fleeting than the perpetrators may have intended).
 - The targets engaged (such as whether critical infrastructure was attacked).
 - The modalities employed in the attack.
 - The extent to which the operation violated agreed-upon (or, at the very least, desired) norms and other obligations undertaken by the perpetrator.
 - Whether the action represents (or is, at least, likely to become) a broader/bolder pattern of behavior or is merely a one-off action.

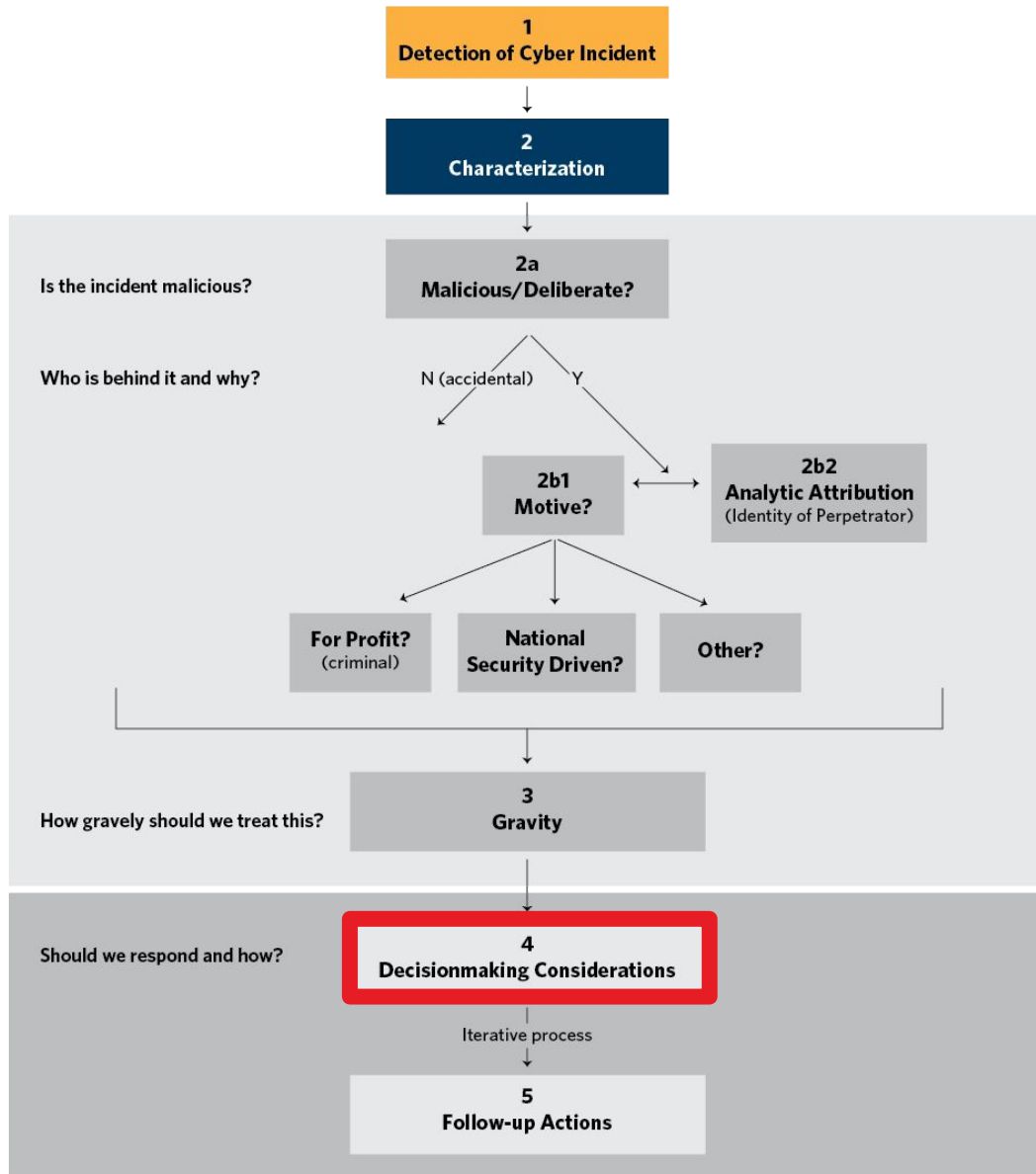
FIGURE 1
Characterization and Attribution Sequence



DECISION MAKING CONSIDERATIONS AND FOLLOW-UP ACTIONS

- Assessment of gravity undoubtedly constitutes an important input into the policy decision making process regarding if and how to respond to the adversarial cyber action, this process has to factor in several additional considerations as well.
- Especially noteworthy in this context are the following issues, ranging from technical and operational all the way to strategic and political:
 - The level of confidence in the attribution as well as the assessment of the adversary's intent.
 - Whether there are operational benefits associated with keeping the incident and/or its nature/perpetrator secret (such as tracking the perpetrators, feeding them misinformation, or encouraging their complacency).
 - Whether public revelation of the incident (or its specific presentation in a certain light) could become a public or political liability that forces unpalatable policy choices. An alternative consideration is whether covering up the incident or inaction in response could also become such a liability.

FIGURE 1
Characterization and Attribution Sequence



DECISION MAKING CONSIDERATIONS AND FOLLOW-UP ACTIONS

(continued)

- Especially noteworthy in this context are the following issues, ranging from technical and operational all the way to strategic and political:
 - Whether public revelation of the incident, the identity of the perpetrator, and/or their intention could yield strategic or political benefits. For example, could it influence the adversary's behavior in a desirable direction? Or is it necessary as a step in responding to the attack in certain ways (for example, to lay the ground for imposing sanctions or indicting the culprits)?
 - The likely economic and other ramifications of public revelation of the incident and its characterization in certain ways. For example, would public attribution prevent businesses from receiving insurance payments for damages because insurers can then legitimately claim that the cyber event was an act of war and therefore not covered?
 - The response options available for response to the attack (besides public condemnation), and how these might be affected by publicity—or lack thereof—around the event.
 - Whether a response—especially a public one—might trigger a reaction from the perpetrator of the attack (potentially others, too) that might dangerously escalate the situation or create other liabilities.

How Cyber Attribution is Done: APT 28

APT28 (also known as Fancy Bear), widely associated with the Russian military intelligence (**GRU**) - Let's explore how they can be attributed.

Phase 1: Initial Technical Triage and Clustering (Level 1)

When an organization is attacked, the first analysis focuses on the technical artifacts:

1. **Initial Access:** Investigators find a malicious link was sent via a spear-phishing email targeting high-value employees.
2. **Malware Analysis:** The payload is analyzed and identified as a custom downloader. The unique string, encryption keys, or function names within the code strongly match artifacts previously observed in attacks known to be conducted by APT28 (e.g., their "**Sednit**" or "**Sofacy**" toolkit).
3. **Command and Control (C2) Analysis:** The malware attempts to beacon out to a domain, for example [update-server\[.\]com](#). This domain's registration patterns, hosting provider, and naming convention match a cluster of known APT28 infrastructure.

Attribution at this stage: This is likely an APT28 attack based on tool and infrastructure reuse.

How Cyber Attribution is Done: APT 28

Phase 2: Behavioral Analysis and TTP Correlation (Level 2)

This is where the analyst moves beyond simple IOCs (which can be changed) and focuses on the TTPs (which are harder to change) to confirm the group:

1. **Lateral Movement TTP:** The analysts observe that the threat actor uses a non-standard Living Off the Land (LOTL) tool, like a specific configuration of PowerShell Remoting or WMI, to move between two compromised servers. This precise combination of tools and methods is a known signature TTP of APT28.
2. **Timing Analysis:** The observed activity—from initial compromise to network reconnaissance—primarily occurs during Eastern European working hours (e.g., 9:00 AM to 5:00 PM Moscow time), a common behavioral indicator for this group.
3. **Victimology:** The victim organization is a major energy sector entity in a NATO country, or a political think tank, which aligns perfectly with APT28's historical pattern of targeting geopolitical entities of interest to Russia.

Attribution at this stage: Confidence is high. The attack matches the toolkit, infrastructure, victim, and TTP profile of APT28.

How Cyber Attribution is Done: APT 28

Phase 3: Strategic/Political Attribution (Level 3)

This level requires intelligence gathering, policy decisions, and often results in public statements or sanctions.

1. **Geopolitical Context:** The attack occurs immediately after a major international political event that directly contradicts Russian foreign policy goals.
2. **Intelligence Correlation:** Government intelligence agencies (e.g., NSA, GCHQ) correlate the APT28 activity with known intelligence operations carried out by the GRU's Unit 26165, observing operational overlap and common tasking orders.
3. **Public Statement:** Based on the high technical confidence (Level 2) and compelling strategic correlation (intelligence, victimology, and geopolitical context), the U.S. government, for example, makes a formal public statement: "We attribute the attacks to the Russian government's military intelligence organization, the GRU."

Attributing the attack to a specific government involves a high-stakes decision-making process because it is essentially a geopolitical act with diplomatic and legal consequences. This final step is usually the domain of governments, not private threat intelligence firms.

USD 81 Million Bangladesh Bank Heist

- In one of the largest cyber heists that took place in February 2016, the Central Bank of Bangladesh (Bangladesh Bank) lost \$81 million from its account held in Federal Reserve Bank of New York.
- The hackers originally attempted to steal a whopping \$951 million in a well-planned sophisticated attack.
- They compromised the bank's network and navigated the SWIFT gateway to send 35 fraudulent fund transfer requests on behalf of the bank.



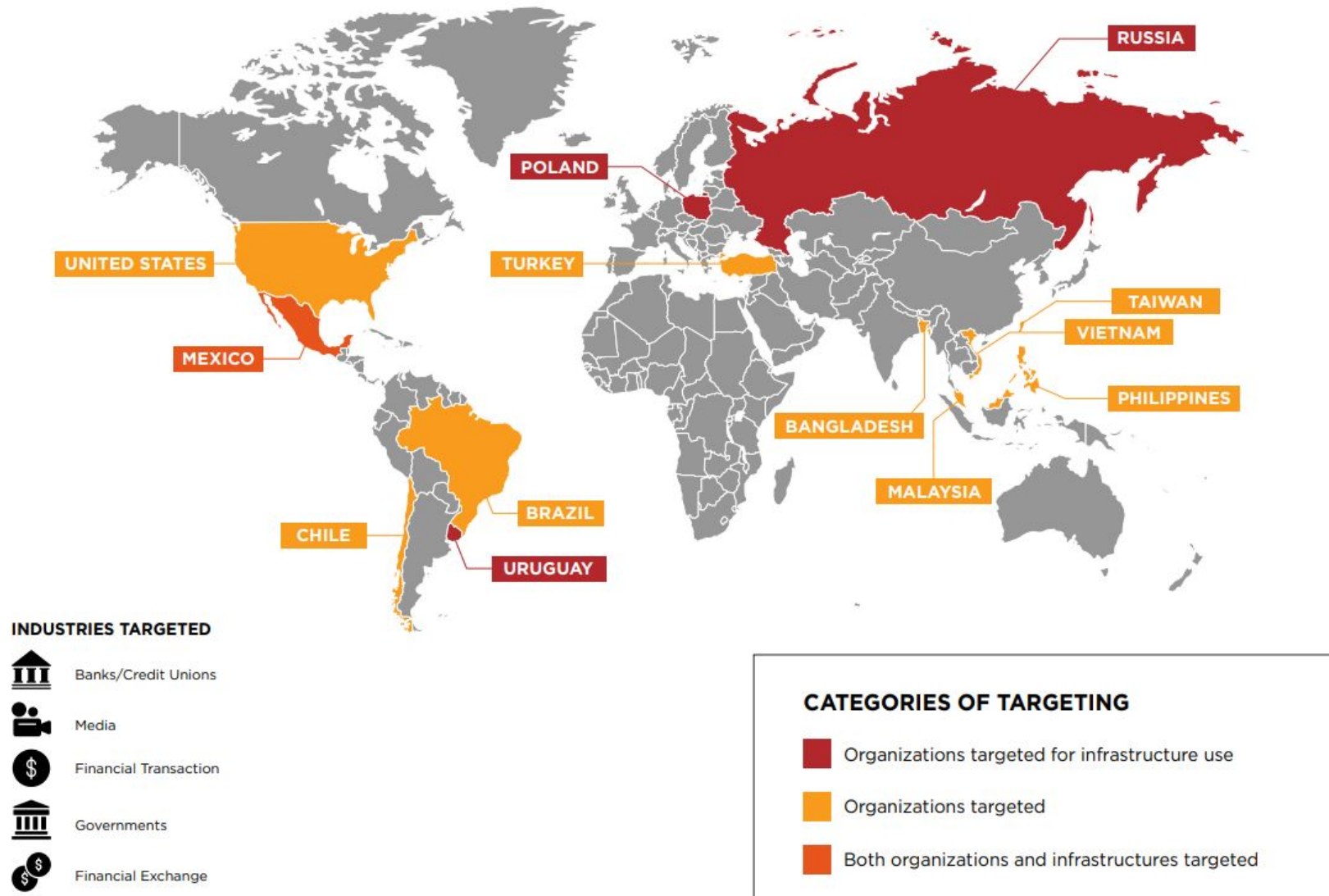
Targeting and Missions

- APT38's primary mission is targeting financial institutions and manipulating inter-bank financial systems to raise large sums of money for the North Korean regime.
- Increasingly heavy and pointed international sanctions have been levied on North Korea following the regime's continued weapons development and testing.
- The pace of APT38 activity probably reflects increasingly desperate efforts to steal funds to pursue state interests, despite growing economic pressure on Pyongyang.
- Since 2015, APT38 has attempted to steal hundreds of millions of dollars from financial institutions.

Some publicly reported attempted heists attributed to APT38 include:

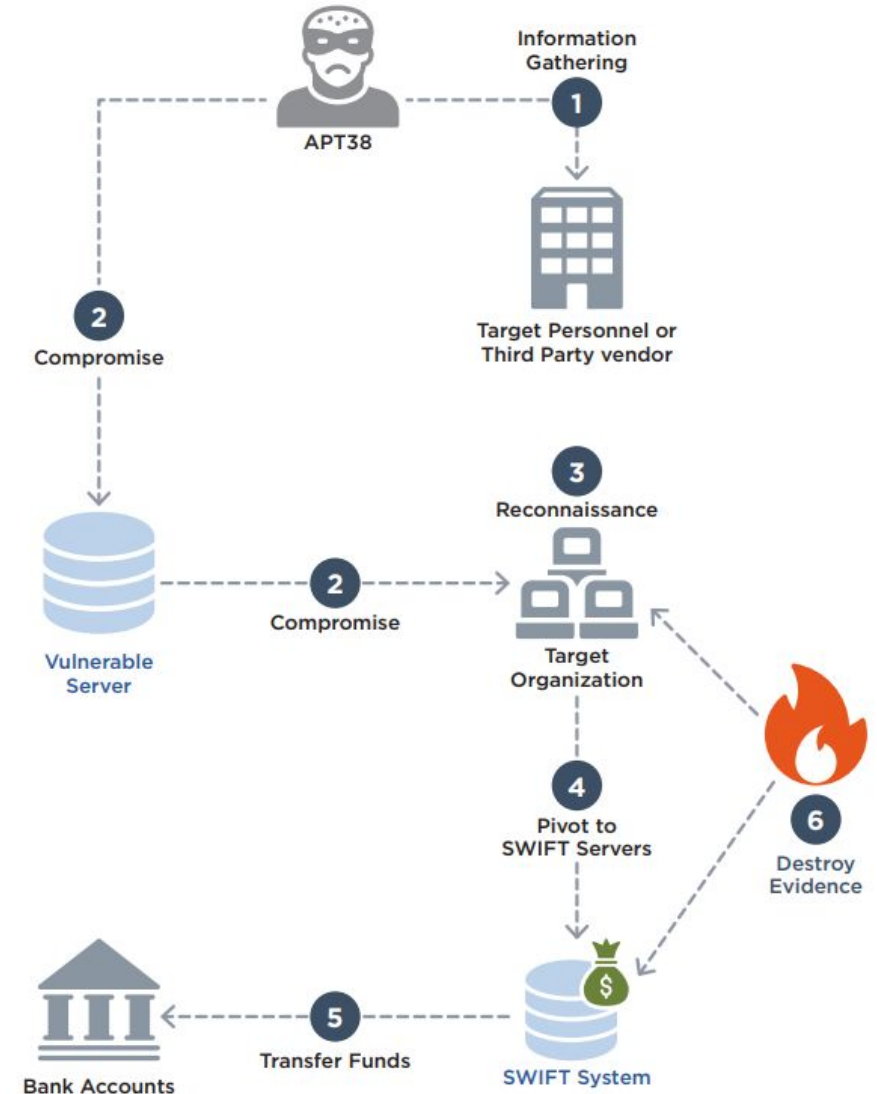
- [Vietnam TP Bank - 2015](#)
- [Bangladesh Bank - 2016](#)
- [Far Eastern Bank Taiwan - 2017](#)
- [Bancomext - 2018](#)
- [Banco De Chile - 2018](#)

Targeting and Missions

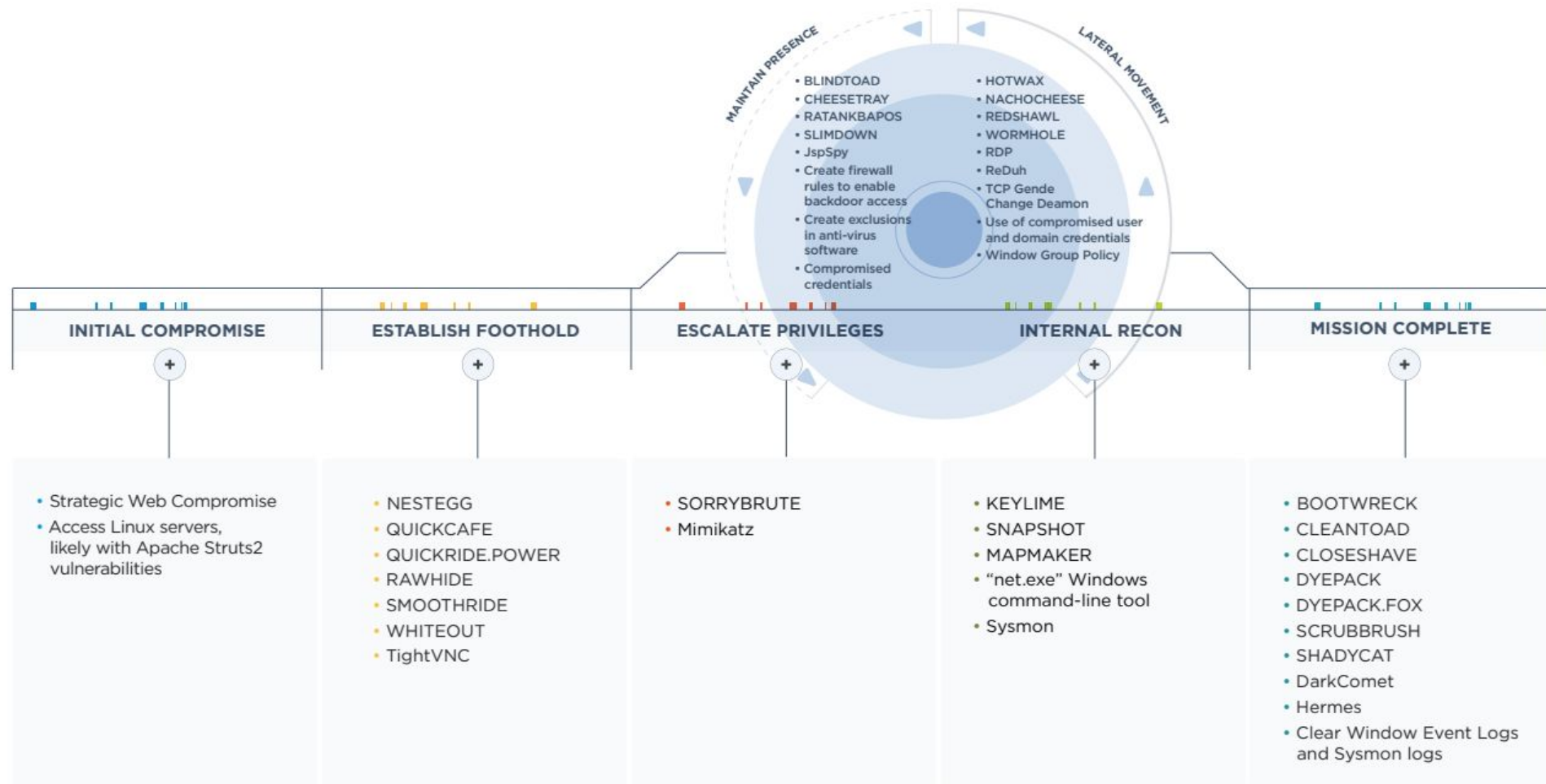


Tactics, Techniques and Procedures

- At a high level, APT38's targeting of financial organizations and subsequent heist attempts have followed the same general pattern



Tactics, Techniques and Procedures



Tactics, Techniques and Procedures

Reconnaissance

- Characteristics:
 - Research into a targeted organization's personnel.
 - Research into a targeted organization's third-party vendors with likely SWIFT system access to understand the mechanics of SWIFT transactions.

Per the DOJ complaint, the email account watsonhenny@gmail.com was used to send LinkedIn invitations to employees of a bank later targeted by APT38.

The same account had a contact list with email addresses for 37 employees of the same targeted bank, suggesting a wider effort to establish connections and potential intrusion vectors.

Tactics, Techniques and Procedures

Initial Compromise

- Characteristics:
 - Watering Hole Attack
 - Searching for Linux servers with Apache Struts 2 vulnerabilities

Per the DOJ report, a watering hole campaign hosted on the website of a Polish financial governing body (Komisja Nadzoru Finansowego, or KNF) was linked to multiple additional watering holes in Latin America as well as a cryptocurrency news page.

These strategic web compromises are believed to have been used to infect multiple organizations, including some in Europe and North America when victims visited the site.

In at least one instance, APT38 actors also exploited an out-of-date version of Apache Struts2 to execute code on a targeted system

Tactics, Techniques and Procedures

Escalate Privileges, Internal Reconnaissance, Maintain Presence

- Characteristics:
 - Deploy malware in a target environment to gather credentials and map the victim's network topology.
 - Use internal tools, such as Sysmon and the net.exe Windows command-line tool, to scan systems.

The group has demonstrated a desire to maintain access to a victim environment for as long as necessary to understand the network layout, necessary permissions, and system technologies to achieve its goals.

APT38 also takes steps to make sure they remain undetected while they are conducting their internal reconnaissance.

Investigators observed that APT38 compromised a SWIFT system and waited almost two years before conducting fraudulent transactions. During that two-year period, APT38 maintained access to the environment, installed and updated backdoors, and monitored activity to learn more about individual users, administrators, and SWIFT systems.

Tactics, Techniques and Procedures

Pivot to SWIFT servers via Internal Reconnaissance

- Characteristics:
 - Install reconnaissance malware and internal network monitoring tools on SWIFT systems to further understand how SWIFT is configured and being used.
 - Deploy active and passive backdoors on SWIFT systems operating at the target organization.

APT38 installed MAPMAKER, a port monitoring tool, on SWIFT systems.

MAPMAKER is a reconnaissance tool that enumerates and prints active TCP connections on the local system. APT38 has used Sysmon and MAPMAKER together to gain a better understanding of the configuration and use of SWIFT systems within victim environments.

Tactics, Techniques and Procedures

Transfer Funds = Mission Success

- Characteristics:
 - Deploy and execute malware that allows APT38 to insert fraudulent SWIFT transactions and alter transaction history
 - Transfer funds to accounts set up in other banks, usually located in separate countries where little oversight enables money laundering.

APT38 relies on DYEPACK, a SWIFT transaction-hijacking framework, to initiate transactions, steal money, and hide any evidence of the fraudulent transactions from the victimized bank.

The group uses DYEPACK to manipulate the SWIFT transaction records and hide evidence of the malicious transactions, so bank personnel are none the wiser when they review recent transactions.

Tactics, Techniques and Procedures

Destroy Evidence

- Characteristics:
 - Securely delete logs and files using non-public malware.
 - Deploy and execute disk-wiping malware to cover tracks and disrupt later forensic analysis.
 - Use publicly available ransomware on the organization's systems to delay SWIFT investigations and destroy remaining evidence of activity.

APT38 carefully identified all systems within an environment (along with the credentials needed to access those systems) and then pushed wiper malware to the selected systems before initiating a massive wipe event.

Some functionality to remove traces of malware were built into the malware itself. For example, DYEPACK includes the ability to uninstall itself by removing its service entry and calling a utility specifically used for secure deletion.

Once the file has been removed, it executes a Windows batch script to also remove the secure deletion utility. In one instance, DYEPACK was configured to self-destruct on a preconfigured date.

Attribution by US DOJ <https://www.justice.gov/archives/opa/press-release/file/1367701/dl>

7
8
9
10
11
12
13
14
15
16
17
18
19
20
21
22
23
24
25
26
27
28

UNITED STATES DISTRICT COURT
FOR THE CENTRAL DISTRICT OF CALIFORNIA
January 2020 Grand Jury

UNITED STATES OF AMERICA, Plaintiff, v. JON CHANG HYOK, aka "Quan Jiang," aka "Alex Jiang," KIM IL, aka "Julien Kim," aka "Tony Walker," and PARK JIN HYOK, aka "Jin Hyok Park," aka "Pak Jin Hek," aka "Pak Kwang Jin," Defendants.	CR 2:20-cr-00614-DMG <u>I N D I C T M E N T</u> [18 U.S.C. § 371: Conspiracy; 18 U.S.C. § 1349: Conspiracy to Commit Wire Fraud and Bank Fraud; 18 U.S.C. §§ 982, 1030: Criminal Forfeiture]
---	--

The Grand Jury charges:

INTRODUCTORY ALLEGATIONS AND DEFINITIONS

At times relevant to this Indictment:

A. The Conspiracy and Defendants

1. The Democratic People's Republic of Korea ("DPRK"), also known as ("aka") North Korea, operated a military intelligence agency called the Reconnaissance General Bureau ("RGB"). The RGB was headquartered in Pyongyang, DPRK, and comprised multiple units.

Attribution

- Mandiant attribute APT38 to North Korean state-sponsored operators based on a combination of technical indicators linking the activity to Pyongyang and details released by DOJ implicating North Korean national Park Jin Hyok in a criminal conspiracy. The DOJ complaint also detailed two blocks of IP addresses used by Park in APT38 and other North Korean operations:

North Korean IP Address Range	Description
175.45.176.0 - 175.45.179.255	IP range registered to a company in Pyongyang
210.52.109.0 - 210.52.109.255	IP range registered to a company in China but leased to North Korea

- Mandiant assess with high confidence that these activities were directed and sponsored by the North Korean government.
- Because the North Korean regime keeps strict control over communications and internet infrastructure in the country, **it is highly improbable that these operations could be conducted without the knowledge or explicit sponsorship of the government.**

Corroboration with 3rd Party Sources

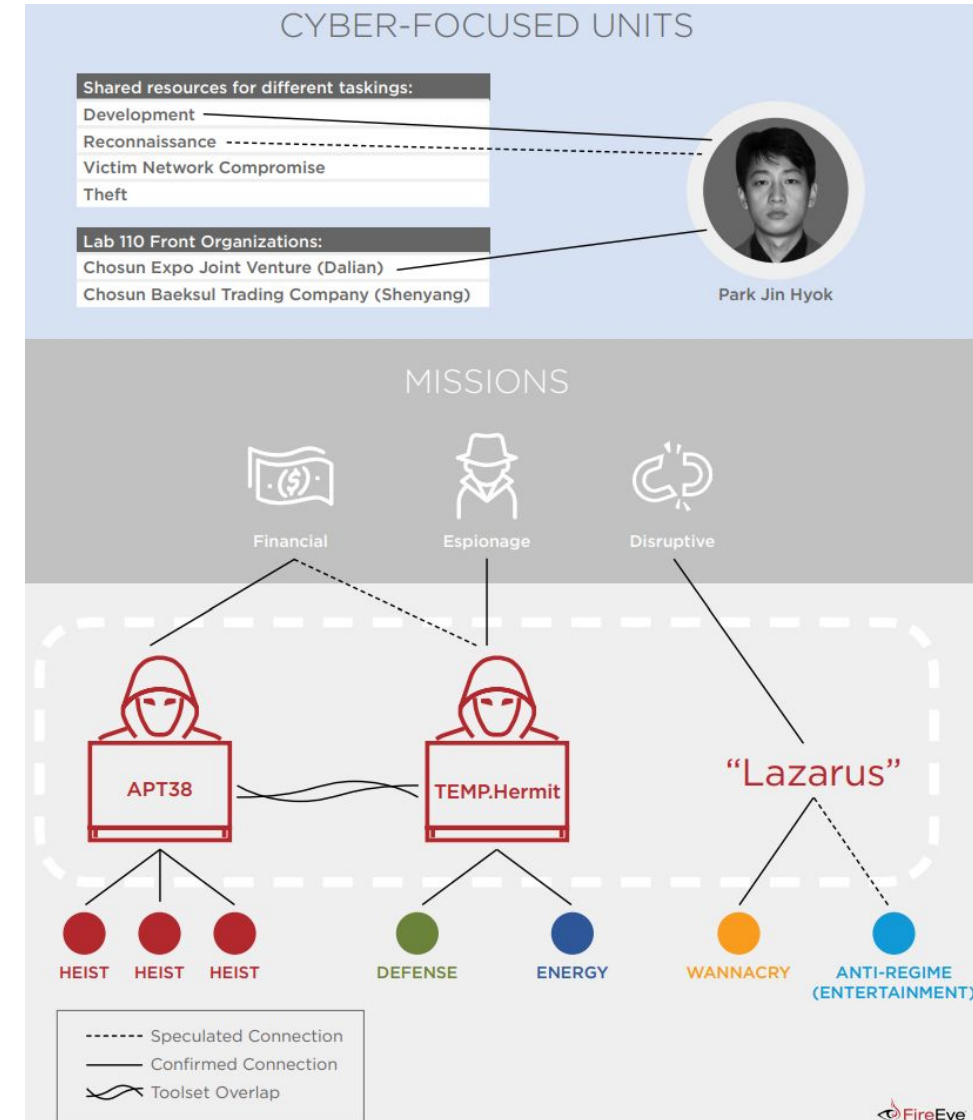
- As detailed in the [DOJ complaint](#), a sample of WHITEOUT (aka Contopee) malware we attribute to APT38 was used between 2015 and 2016 against a Southeast Asian bank. The sample used a specific DDNS domain, onlink.epac[.]to, which was managed by an account at a DDNS provider. The same account was accessed on October 6, 2015 from a North Korean IP address.
- As detailed in the [DOJ complaint](#), the North Korean operators conducted reconnaissance on a Southeast Asian bank, including visiting its website, researching the business identifier code (BIC) used by the SWIFT system to uniquely identify the bank, and the BIC code for a corresponding bank needed to carry out the intended fraudulent transactions.
- This is evidence of shared motivation and intent to target the SWIFT system by the North Korean operators performing the reconnaissance and APT38 which later targeted that organization.

Corroboration with 3rd Party Sources

- The use of these ranges by APT38 for their operations has been **corroborated** by third-party reporting:
 - A public report by Group-IB indicated APT38 logged into watering hole domains associated with (brou.com[.]uy, cnbv.gob[.]mx knf.gov[.]pl) from **two IPs (210.52.109[.]22 and 175[.]45.178.222)** within the same North Korean IP ranges.
 - A report by Kaspersky indicates APT38 also logged into an Apache Tomcat server used to host its malicious files from the **same IP range (175[.]45.176.0 -175[.]45.179.255)** in January 2017.

Corroboration with 3rd Party Sources

- Based on details published in the DOJ complaint against North Korean programmer Park Jin Hyok, APT38 and other cyber operators linked to TEMP.Hermit are associated with Lab 110, an organization subordinate to or synonymous with the 6th Technical Bureau in North Korea's Reconnaissance General Bureau (RGB).
- The organization is **believed to leverage front organizations to mask their activities**, including infiltrating networks and gathering intelligence.



Corroboration with 3rd Party Sources

- The DOJ complaint and open sources report that Lab 110 operates out of front companies typically based in northeast China.
- Identified fronts include **Chosun Expo Joint Venture** in Dalian and **Chosun Baeksul Trading Company** in Shenyang.
- Firsthand accounts, information provided by a foreign investigative agency, and common IP addresses used to access the company website and associated accounts while connecting to and from North Korea corroborate reports that Chosun Expo was a front company operated by authorities in Pyongyang.

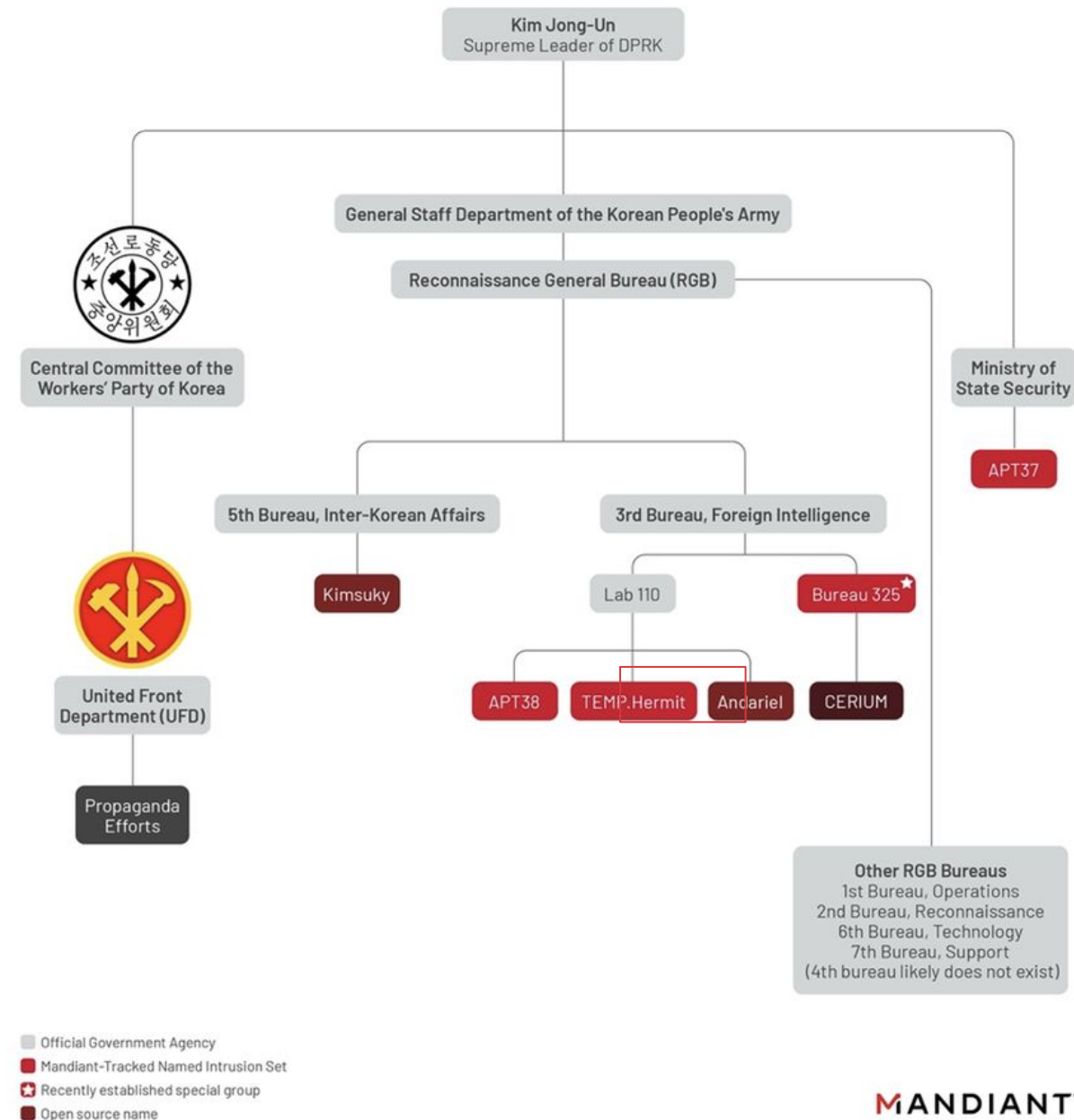


Corroboration with 3rd Party Sources

- Malware developers and other adversary actors are believed to be recruited out of North Korea's universities and directly into military units, such as Lab 110.
- Schools reportedly feeding into these units include Kim Chaek University of Technology and Kim Il Sung Military Science University



ASSESSED STRUCTURE OF DPRK CYBER PROGRAMS



Thank You